INSTITUTO TECNOLOGICO SUPERIOR PROGRESO

CARRERA:
INGENIERIA EN SISTEMAS COMPUTACIONALES

GRADO Y GRUPO:
9no - Grupo 1

MATERIA:
PENTESTING

TAREA:
Proyecto colaborativo: Plan de pentesting básico.

FECHA DE ENTREGA:
Septiembre de 2026

ESTUDIANTE:
Carlos Eduardo Valencia Hernández

Osvaldo Canul Canul

DOCENTE:

MARTÍNEZ GARCÍA HOLZEN



Tabla de contenido

1. Introducción *3*

2. Alcance del Pentesting *5*

Objetivo general 5

Objetivos específicos 5

Objetivos (Target URLs y Endpoints) 6

Roles para probar 6

Áreas excluidas (Out-of-Scope) 7

Áreas de prueba según OWASP Top 10 y OWASP API Security Top 10 ..... *8*

Arsenal de herramientas y justificación técnica *8*

3. Tipos de prueba *10*

Análisis comparativo de los tres enfoques (Caja Negra, Blanca y Gris) 10

Justificación de la selección: Caja Gris (Grey Box) 11

4. Ventana de Usuario y Consideraciones Temporales *12*

Concepto teórico de la ventana de usuario en ciberseguridad 12

Política de Congelamiento de Cambios (Change Freeze) 13

Canales de comunicación y contacto de emergencia 13

5. Roles y Responsabilidades *14*

Estructura de gobernanza y actores del proyecto 14

Matriz RACI del proyecto de pentesting 15

6. Reglas de Operación (RoE) 16

Lineamientos y reglas de compromiso continuo 17

7. Conclusiones y Reflexiones del Equipo *18*



2026 año de Margarita Maza



1. Introducción

El presente documento técnico y metodológico tiene como propósito formalizar el diseño integral de un plan básico de prueba de penetración (pentesting) concebido específicamente para la organización "Farmacias del Mayab S.A. de C.V.", empresa de referencia en el sector farmacéutico y de distribución médica en el sureste de México, con sede central en Progreso y Mérida, Yucatán. La organización opera actualmente una red comercial de 45 sucursales físicas y ha consolidado una fuerte presencia digital a través de su plataforma omnicanal "MediMayab", la cual integra una aplicación web de comercio electrónico, un módulo de validación de recetas médicas electrónicas y una API REST que gestiona inventarios en tiempo real, cobros y facturación fiscal para miles de clientes. Ante el incremento del volumen transaccional y la digitalización de tratamientos médicos, la Dirección de Tecnologías de la Información de Farmacias del Mayab ha solicitado el diseño formal de este plan para evaluar de forma ordenada, ética y controlada la postura de seguridad de su infraestructura digital expuesta.

Es fundamental puntualizar que este instrumento no representa la ejecución material de los ciberataques, sino la etapa estratégica de planeación previa. En la disciplina de la seguridad ofensiva, la planeación formal constituye más del 70% del éxito de cualquier auditoría: realizar una prueba de penetración sin un alcance nítidamente acotado, sin reglas de compromiso estrictas, sin una delimitación temporal consensuada y sin roles autorizados transforma un ejercicio profesional en una actividad de alto riesgo operativo que puede desembocar en la caída no deseada de los servidores de venta, la corrupción de registros médicos o la incurrencia involuntaria en delitos informáticos conforme al marco normativo vigente.

En el contexto actual, la ciberseguridad se ha consolidado como un requisito vital para cualquier organización que gestione transacciones digitales y datos personales. Para Farmacias del Mayab, la materialización de un incidente de seguridad trasciende las pérdidas económicas inmediatas: implica el riesgo inminente de exfiltración de datos de salud altamente sensibles (diagnósticos clínicos y tratamientos farmacológicos), catalogados como datos especialmente protegidos por la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP) y la Norma Oficial Mexicana NOM-024-SSA3-2012, además del compromiso de información bancaria sujeta a rigurosas sanciones financieras y normativas bajo los estándares internacionales de PCI-DSS.





El pentesting se erige como la metodología más contundente para anticiparse a estos riesgos, permitiendo que la organización abandone la postura defensiva tradicional netamente reactiva —que suele depender de alarmas y registros posteriores al ataque— para adoptar una postura de resiliencia proactiva. Al simular metódicamente el comportamiento y las tácticas de un atacante real antes de que un cibercriminal explote las brechas existentes, la alta dirección podrá dimensionar con exactitud el impacto práctico de sus vulnerabilidades, priorizar las inversiones de corrección tecnológica y salvaguardar la confianza de sus pacientes en Yucatán.



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx



2. Alcance del Pentesting

Objetivo general

Evaluar la postura de seguridad y el nivel de resiliencia de la infraestructura digital de Farmacias del Mayab S.A. de C.V. mediante la formulación y ejecución simulada de una prueba de penetración en modalidad de Caja Gris, fundamentada en la metodología OWASP Web Security Testing Guide (WSTG v4.2) y el OWASP API Security Top 10, con el propósito de identificar, validar y clasificar vulnerabilidades explotables que puedan comprometer la confidencialidad de los datos clínicos de los pacientes, la integridad de las transacciones financieras o la disponibilidad de la plataforma MediMayab.

Objetivos específicos

- **Identificar fallas de inyección:** Detectar inyecciones SQL, NoSQL y manipulación de comandos en parámetros de búsqueda del catálogo y filtros de existencias de medicamentos.
- **Auditar controles de acceso (BOLA y BFLA):** Verificar si usuarios de perfil cliente o cajero pueden alterar identificadores en la API para acceder a recetas médicas ajenas o funciones de administración.
- **Evaluar autenticación y sesiones:** Examinar la robustez de las sesiones basadas en JSON Web Tokens (JWT), resistencia a ataques de fuerza bruta y políticas de expiración de credenciales.
- **Verificar controles criptográficos:** Comprobar la configuración adecuada de TLS 1.3, algoritmos de cifrado simétrico y el resguardo de datos sensibles de tarjetas bancarias.
- **Auditar la subida de recetas médicas:** Validar que el módulo de carga de recetas impida la subida y ejecución de código malicioso (webshells) en el servidor de almacenamiento.
- **Revisar configuraciones del servidor:** Identificar cabeceras HTTP faltantes (HSTS, CSP), servicios expuestos innecesariamente y librerías desactualizadas con vulnerabilidades conocidas (CVEs).
- **Generar plan de remediación:** Entregar un reporte técnico y ejecutivo clasificado mediante CVSS v3.1 con recomendaciones prácticas para la corrección priorizada de los hallazgos.





Objetivos (Target URLs y Endpoints)

Las pruebas se concentrarán exclusivamente sobre los tres componentes centrales expuestos del cliente:

- **https://tienda.farmaciasdelmayab.com.mx:** Aplicación web principal para clientes finales. Incluye catálogo, carrito de compras, registro, login, pasarela de pago y carga de recetas médicas.
- **https://api.farmaciasdelmayab.com.mx/v2:** Interfaz de programación (API REST) que sirve como núcleo de datos para la tienda web, las terminales de punto de venta (POS) y la futura app móvil.
- **https://pos-web.farmaciasdelmayab.com.mx:** Portal web ligero para operadores de farmacia y cajeros de sucursal, empleado para consultar recetas y validar entregas locales.

Roles para probar

1. **Usuario no autenticado (Unauthenticated / Público):** Simula un atacante anónimo de internet sin credenciales que explora rutas públicas, catálogo y formularios de registro e inicio de sesión.
2. **Paciente / Cliente registrado (Standard Customer):** Simula a un cliente legítimo que realiza pedidos, consulta su historial, sube recetas médicas y administra sus tarjetas guardadas.
3. **Operador de Farmacia / Cajero de Sucursal (Branch Operator):** Simula a un empleado de sucursal con permisos para validar recetas, verificar existencias locales y autorizar despachos.
4. **Administrador de Sistemas (System Admin):** Perfil con privilegios elevados para configuración global, catálogo de precios, gestión de usuarios y generación de reportes financieros.





Áreas incluidas (In-Scope)

- **Módulos de autenticación:** Registro de usuarios, inicio de sesión, recuperación de contraseña, generación y validación de tokens JWT.
- **Comercio electrónico:** Gestión de carrito de compras, cálculo de promociones, aplicación de cupones y checkout.
- **Carga de documentos:** Mecanismos de validación de extensiones y tipos MIME en el módulo de recetas médicas.
- **Endpoints de la API REST v2:** Rutas CRUD de productos, recetas, inventarios, pedidos y perfiles de usuario.
- **Configuración de servidores web:** Servidor Nginx, políticas de CORS, cabeceras HTTP de seguridad y cookies.

Áreas excluidas (Out-of-Scope)

- **Infraestructura física:** Las 45 sucursales, almacenes, oficinas corporativas y centros de distribución.
- **Servicios de pasarelas de pago de terceros:** Servidores externos propiedad de proveedores bancarios (ej. Openpay, Stripe).
- **Consola de administración cloud:** Consolas de gestión de infraestructura de AWS/Azure que no pertenezcan al aplicativo.
- **Pruebas de ingeniería social:** Ataques de phishing, vishing o engaño dirigidos a los empleados o farmacéuticos.
- **Ataques de denegación de servicio (DoS/DDoS):** Queda prohibido saturar el ancho de banda o agotar la memoria de los servidores.
- **Modificación destructiva de datos de producción:** No se alterarán inventarios reales ni bases de datos de clientes reales.





Áreas de prueba según OWASP Top 10 y OWASP API Security Top 10

- **A01:2025 / API1:2023 – Broken Object Level Authorization (BOLA / IDOR):** Verificación de manipulación de IDs en endpoints `/api/v2/recetas/{id}` para consultar expedientes de terceros.
- **A02:2025 – Security Misconfiguration:** Detección de errores detallados, modo debug activo, cabeceras faltantes y puertos innecesarios.
- **A03:2025 / API3:2023 – Broken Object Property Level Authorization:** Validación de asignación masiva de campos protegidos (ej. modificar precios unitarios o roles en JSON).
- **A04:2025 – Cryptographic Failures:** Identificación de algoritmos criptográficos obsoletos y transmisión insegura de credenciales o tokens.
- **A05:2025 – Injection:** Inyecciones SQL en filtros de búsqueda del catálogo e inyección de comandos en rutinas de facturación.
- **A06:2025 – Insecure Design & File Upload Flaws:** Verificación de almacenamiento aislado y validación estricta al subir recetas médicas.
- **A07:2025 / API2:2023 – Broken Authentication:** Evaluación de ataques de fuerza bruta en logins, debilidad en firmas JWT y falta de expiración.
- **A08:2025 / API5:2023 – Broken Function Level Authorization (BFLA):** Comprobación de que clientes o cajeros no puedan invocar rutas administrativas de la API.
- **A09:2025 – Security Logging and Alerting Failures:** Revisión de registros de auditoría y generación de alertas ante múltiples accesos fallidos.
- **A10:2025 / API4:2023 – Lack of Rate Limiting:** Validación de mecanismos de límite de tasa para prevenir enumeración automatizada y abuso de cupones.

Arsenal de herramientas y justificación técnica

- **Burp Suite Professional:** Herramienta insignia para interceptación y manipulación de tráfico HTTP/S, escaneo activo y análisis de lógica de negocio.
- **Postman / Newman:** Plataforma de pruebas para APIs REST, automatización de payloads JSON y validación de Bearer tokens.





- **Nmap:** Mapeo de puertos, identificación de servicios de red y descubrimiento de versiones del servidor web.
- **SQLMap:** Detección y comprobación controlada de inyecciones SQL en parámetros vulnerables previamente localizados.
- **OWASP ZAP:** Escáner complementario para validación de alertas pasivas y activas en el entorno web.
- **ffuf (Fast Web Fuzzer):** Fuzzing de alto rendimiento para descubrimiento de rutas ocultas, archivos residuales y parámetros en la API.
- **jwt_tool:** Suite para auditoría de seguridad sobre tokens JSON Web Token, validación de firmas y manipulación de claims.
- **Browser DevTools:** Inspección de almacenamiento local, almacenamiento de sesión, atributos de cookies y cabeceras de respuesta.





3. Tipos de prueba

Análisis comparativo de los tres enfoques (Caja Negra, Blanca y Gris)

En la disciplina de las pruebas de penetración, la modalidad de evaluación se determina en función del volumen de información técnica previa y el grado de acceso que la empresa evaluada otorga al equipo auditor. Los estándares internacionales reconocen tres enfoques metodológicos:

- **Caja Negra (Black Box):** El equipo evaluador no recibe ninguna información técnica interna de la plataforma; únicamente se le suministran los dominios públicos. Simula el punto de vista de un atacante externo anónimo sin privilegios previos. Su fortaleza es el realismo operativo; no obstante, presenta una baja eficiencia en tiempo, ya que consume gran parte del presupuesto en recolección pasiva (OSINT) y escaneos a ciegas, limitando la profundidad del análisis de la lógica de negocio.
- **Caja Blanca (White Box):** El equipo evaluador cuenta con visibilidad y acceso absoluto: código fuente de la aplicación, diagramas de arquitectura de red, credenciales de administración y documentación de bases de datos. Ofrece una cobertura técnica exhaustiva; sin embargo, tiene un costo económico muy alto, requiere tiempos extensos y se aleja de la perspectiva real de un atacante del mundo exterior.
- **Caja Gris (Grey Box):** Es el esquema más eficiente y representativo en la industria. El cliente entrega información técnica parcial y relevante (documentación de endpoints de la API y credenciales de usuario con distintos niveles de privilegio), pero sin revelar el código fuente ni la red interna. Simula al usuario interno, al cliente malicioso o al atacante que ya ha obtenido una cuenta estándar y busca vulnerar los controles de autorización.

Modalidad	Información Otorgada	Perspectiva Simulada	Tiempo / Esfuerzo	Cobertura Técnica
Caja Negra	Nula (solo dominios públicos)	Atacante externo anónimo	Elevado en reconocimiento	Superficial / Perimetral
Caja Blanca	Total (código, red, admin)	Auditor interno / Desarrollador	Muy extenso y exhaustivo	Máxima / Integral





Caja Gris	Parcial (endpoints y cuentas)	Cliente o empleado malicioso	Optimizado y eficiente	Alta en lógica y control de acceso

Justificación de la selección: Caja Gris (Grey Box)

Para el proyecto de Farmacias del Mayab S.A. de C.V., el equipo evaluador ha determinado de manera fundada y técnica la selección de la modalidad de **Caja Gris (Grey Box)** como la más idónea y ventajosa, fundamentada en cuatro factores:

1. **Optimización del tiempo y costo de auditoría:** Evita malgastar días valiosos en recolectar información pública evidente y permite enfocar de inmediato el esfuerzo en las áreas críticas: pasarela de pago, validación de recetas y endpoints de la API.
2. **Simulación del vector de amenaza más peligroso:** Más del 85% de las brechas en plataformas e-commerce y de salud provienen de usuarios autenticados que intentan manipular peticiones para acceder a datos ajenos (fallas BOLA/IDOR). La caja gris permite evaluar este riesgo con rigor absoluto.
3. **Validación exhaustiva de la matriz de segregación de roles:** Al disponer de credenciales para rol Paciente y rol Cajero, se pueden ensayar intentos directos de escalada horizontal y vertical sin depender de adivinanzas.
4. **Protección de propiedad intelectual:** Farmacias del Mayab no se ve obligada a compartir sus repositorios de código fuente con consultores externos, resguardando el secreto de sus algoritmos comerciales.



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx



4. Ventana de Usuario y Consideraciones Temporales

Concepto teórico de la ventana de usuario en ciberseguridad

En la gestión de proyectos de seguridad informática y auditoría ofensiva, la **ventana de usuario** (o ventana de pruebas / maintenance testing window) se define formalmente como el período horario específico, acordado y rubricado por ambas partes en el contrato de servicio, durante el cual se faculta al equipo evaluador para emitir tráfico ofensivo, escaneos e inyecciones sobre la infraestructura evaluada.

Su objetivo primordial consiste en salvaguardar la estabilidad operativa y comercial de la organización. Toda prueba de penetración genera un volumen anormal de peticiones con cargas útiles complejas que pueden sobrecargar bases de datos o disparar alarmas en los centros de monitoreo. La ventana de usuario delimita con exactitud cuándo los analistas pueden realizar pruebas intrusivas para no afectar a los clientes legítimos durante las horas pico de compras.

Aplicación y calendario operativo en Farmacias del Mayab

Con base en el análisis de tráfico transaccional de Farmacias del Mayab S.A. de C.V., el volumen de compra en línea y consulta de recetas desciende a sus niveles mínimos entre las 00:00 y las 05:00 horas. Por tanto, se establecen los siguientes bloques temporales:

- **Ventana de Pruebas Intrusivas y Automatizadas (00:00 a 05:00 horas):** De martes a viernes. En este bloque nocturno se autoriza el uso de herramientas automatizadas de fuzzing (ffuf), escaneo de vulnerabilidades (Burp Scanner, SQLMap) e inyecciones de payloads en endpoints de la API y formularios web.
- **Ventana de Validación Pasiva y Manual (05:00 a 07:00 horas):** Verificación puntual de hallazgos mediante navegación manual a bajo ritmo, comprobación de consistencia de la base de datos y revisión de que los servicios no presenten degradación antes del inicio de la jornada comercial.
- **Horario Comercial Diurno (07:00 a 23:59 horas):** Prohibición categórica de lanzar escaneos automatizados, pruebas de estrés o inyecciones masivas sobre los servidores productivos. Únicamente se permite análisis estático documental y redacción de reportes.





Política de Congelamiento de Cambios (Change Freeze)

Durante el período completo que abarquen las semanas de evaluación, la Dirección de TI de Farmacias del Mayab se compromete formalmente a establecer una política de **Congelamiento de Cambios (Change Freeze)** sobre la infraestructura de MediMayab. Esto implica que los desarrolladores internos y administradores de sistemas no realizarán nuevos despliegues de código (deploys), actualizaciones de parches en servidores ni modificaciones en las reglas del Web Application Firewall (WAF). Esta medida es vital para garantizar que los resultados obtenidos por los evaluadores sean reproducibles, consistentes y no se distorsionen por modificaciones intermedias en el software.

Canales de comunicación y contacto de emergencia

Para gestionar de forma ágil cualquier imprevisto técnico durante las ventanas nocturnas, se establece un canal de comunicación directo 24/7 mediante un grupo cifrado seguro (Microsoft Teams / Signal) y un enlace telefónico dedicado entre el Líder del Equipo de Pentesting y el Responsable de Monitoreo de Farmacias del Mayab. Si se detecta un incremento anómalo en el uso de CPU o la caída involuntaria de un microservicio, la comunicación inmediata permitirá aislar la causa en cuestión de minutos.

Plan de contingencia y marcha atrás (Rollback)

El equipo evaluador mantendrá un registro minucioso de cada cuenta, registro y archivo temporal creado durante las pruebas. Al término de cada sesión nocturna se ejecutará un procedimiento de limpieza y reversión (rollback) para eliminar carritos de prueba, recetas ficticias y desbloquear credenciales que hayan sido suspendidas por intentos fallidos de autenticación, garantizando que a las 07:00 horas el sistema opere en un estado 100% íntegro para el público general.





5. Roles y Responsabilidades

Estructura de gobernanza y actores del proyecto

Para que la prueba de penetración se desarrolle con total profesionalismo, rigor ético y validez jurídica, es imperativo definir con exactitud las atribuciones de cada uno de los actores involucrados en el proyecto:

1. **Cliente (Farmacias del Mayab S.A. de C.V.):** Actúa como la entidad contratante y propietaria de los activos digitales. Su Gerencia de Tecnologías de la Información funge como contraparte técnica operativa encargada de proveer el alcance autorizado, suministrar las credenciales de prueba para los roles y garantizar que las copias de seguridad de las bases de datos estén al día.
2. **Equipo de Pruebas (Pentesters de Ciberseguridad Ofensiva):** Grupo especializado encargado de la ejecución técnica de las pruebas siguiendo estrictamente el alcance y la metodología acordados. Sus responsabilidades comprenden la documentación detallada de cada hallazgo con evidencias reproducibles (PoC), el escalamiento inmediato ante riesgos críticos y la formulación del informe final de remediación.

- **Líder del Proyecto y Pentester Principal (Valencia Hernández Carlos Eduardo):** Supervisa la conducción global del proyecto, actúa como canal de interlocución principal frente a la gerencia del cliente, coordina la ejecución de pruebas web en el portal de comercio electrónico y valida la calidad del informe final.
- **Pentester Técnico y Especialista en APIs (Canul Canul Osvaldo):** Responsable de la auditoría técnica profunda sobre la API REST v2 (`/api/v2`), ejecución de pruebas de fuzzing, análisis de seguridad en tokens JWT, pruebas de autorización BOLA/BFLA y elaboración de las recomendaciones técnicas de mitigación.

3. **Responsables de Autorización (Sponsors Directivos y Legales):** Figura de máxima jerarquía corporativa en Farmacias del Mayab (Dirección General y Representante Legal, en coordinación con el Oficial de Seguridad CISO). Tiene la facultad legal indelegable de rubricar el contrato formal de servicios y la carta de consentimiento explícito ("Get Out of Jail Free letter"), amparando legalmente al equipo evaluador y actuando como máxima instancia de resolución ante cualquier contingencia.





Matriz RACI del proyecto de pentesting

A continuación se presenta la matriz de responsabilidades RACI (R = Responsable de ejecutar, A = Aprobador final, C = Consultado, I = Informado) para cada fase del proyecto:

Fase / Actividad del Proyecto	Líder Pentest (Carlos V.)	Pentester API (Osvaldo C.)	Gerente TI (Cliente)	Director / Sponsor
Definición de Alcance y RoE	**R**	C	**A**	**A**
Reconocimiento y Mapeo de APIs	**R**	**R**	I	I
Ejecución de Pruebas de Intrusión	**R**	**R**	C	I
Notificación de Hallazgos Críticos	**R**	**R**	**A**	I
Elaboración de Reportes Técnicos	**R**	**R**	C	I
Cierre y Presentación Ejecutiva	**R**	C	**A**	**A**





6. Reglas de Operación (RoE)

Las Reglas de Operación o Reglas de Compromiso (Rules of Engagement - RoE) constituyen el documento vinculante y de mayor trascendencia ética y legal en una prueba de penetración. Su propósito fundamental es delimitar las líneas rojas que el equipo evaluador no puede traspasar bajo ninguna circunstancia, garantizando que el ejercicio se desenvuelva con estricto apego al marco normativo de los Artículos 211 bis 1 al 7 del Código Penal Federal mexicano y preservando la continuidad de las operaciones de Farmacias del Mayab S.A. de C.V. A continuación se presentan las primeras cuatro reglas esenciales:

- **Regla 1: No afectación a la disponibilidad ni denegación de servicio (DoS/DDoS prohibido).** El equipo evaluador tiene estrictamente prohibido ejecutar ataques de denegación de servicio distribuido, inundaciones SYN/UDP o cualquier prueba de estrés orientada a colapsar los servidores web o de bases de datos. Si una herramienta automatizada comienza a elevar la latencia de respuesta por encima de 1500 ms, la prueba debe pausarse inmediatamente.
- **Regla 2: Confidencialidad absoluta y secreto profesional (Acuerdo NDA).** Toda la información recabada, credenciales de prueba, diagramas de arquitectura, datos de compras y vulnerabilidades detectadas durante la evaluación se considerarán secretos comerciales bajo un Acuerdo de No Divulgación (NDA). Queda terminantemente prohibida su transmisión a terceros o publicación pública sin autorización judicial o consentimiento por escrito del cliente.
- **Regla 3: Notificación inmediata de hallazgos críticos (<1 hora).** En el supuesto de que el equipo evaluador descubra una vulnerabilidad de severidad crítica (CVSS superior a 9.0) —tal como una ejecución remota de código (RCE), acceso no autenticado a la base de datos de pacientes o exposición directa de credenciales de la pasarela de pagos bancarios—, se suspenderá la explotación de dicho vector y se emitirá una alerta inmediata en menos de 60 minutos al CISO y Gerente de TI para su remediación urgente.
- **Regla 4: Prohibición estricta de exfiltración o modificación masiva de datos reales de clientes.** En caso de que una falla de autorización (BOLA/IDOR) o inyección SQL permita el acceso a tablas que contengan expedientes médicos o datos personales de clientes reales, los evaluadores se abstendrán de descargar o almacenar copias de la base de datos. Como prueba de concepto (PoC), únicamente se documentará un único registro ofuscado o se utilizarán las cuentas de prueba creadas ex profeso.





Lineamientos y reglas de compromiso continuo

Complementando las directivas anteriores, se establecen las reglas de control técnico, trazabilidad y contención de emergencia que normarán las acciones operativas durante toda la auditoría:

- **Regla 5: Respeto irrestricto al alcance definido y áreas excluidas.** El equipo evaluador se compromete a no interactuar ni emitir tráfico contra dominios, servidores de correo electrónico o infraestructura no contemplados en la sección de alcance. Si durante el reconocimiento se descubren subdominios o paneles de sucursales no listados, se solicitará autorización formal por escrito antes de realizar cualquier escaneo.
- **Regla 6: Empleo exclusivo de credenciales y datos de prueba.** Las credenciales suministradas por el cliente para los roles de Paciente, Cajero y Administrador solo podrán emplearse para los fines de esta auditoría. Queda prohibido reutilizarlas en servicios externos o compartirlas fuera del equipo de dos pentesters formalmente acreditados.
- **Regla 7: Trazabilidad técnica obligatoria mediante IPs de origen fijas y cabeceras HTTP.** Todo el tráfico generado por el equipo evaluador provendrá exclusivamente de dos direcciones IP estáticas previamente registradas en el contrato. Asimismo, cada petición web y llamada a la API incluirá la cabecera HTTP personalizada `X-Pentest-Authorized: MediMayab-Audit-2026`, permitiendo al equipo de monitoreo del cliente auditar en tiempo real qué eventos corresponden a la auditoría legítima.
- **Regla 8: Protocolo de interrupción inmediata ("Botón Rojo").** Farmacias del Mayab se reserva el derecho unilateral de solicitar en cualquier instante la detención fulminante de las actividades mediante una orden telefónica o por mensaje al Líder del Pentest. Ante la activación del 'Botón Rojo', el equipo suspenderá todos los scripts y procesos en un tiempo máximo de tres minutos, procediendo a una sesión de evaluación conjunta.

El estricto cumplimiento de estas ocho reglas asegura que la prueba de penetración se lleve a cabo como un ejercicio de ingeniería de software altamente profesional, protegiendo a la empresa contra cualquier degradación de sus servicios y amparando al equipo evaluador bajo un marco ético indiscutible.





7. Conclusiones y Reflexiones del Equipo

Valencia Hernández Carlos Eduardo

Al desarrollar este plan básico de pentesting para Farmacias del Mayab S.A. de C.V., pude comprender que la seguridad ofensiva profesional dista enormemente de la concepción popular de ejecutar herramientas automatizadas para vulnerar sistemas. Mi aprendizaje más significativo radicó en entender que la planeación estratégica y la delimitación del alcance son los pilares fundamentales que otorgan validez técnica y protección legal al evaluador. Antes de esta práctica, solía percibir las auditorías como desafíos puramente técnicos; sin embargo, al redactar los objetivos generales, específicos y las áreas excluidas, descubrí que una mala definición del alcance puede poner en riesgo la viabilidad operativa de una empresa y acarrear graves responsabilidades legales conforme al Código Penal Federal mexicano.

Asimismo, el diseño de la estructura de roles y responsabilidades me demostró que el líder de un proyecto de ciberseguridad debe poseer sólidas habilidades de comunicación gerencial y pensamiento preventivo: saber cómo coordinar ventanas de bajo tráfico, consensuar canales de contingencia y garantizar que un ejercicio de intrusión no interfiera con las ventas de una cadena farmacéutica es tan crítico como saber explotar una falla de inyección. Esta experiencia consolidó mi visión de que el pentester moderno debe ser un aliado estratégico del negocio que ayuda a blindar los activos de información más sensibles.

Canul Canul Osvaldo

Mi principal contribución y aprendizaje a lo largo de este proyecto colaborativo se centró en el análisis de los tipos de prueba y la estructuración técnica de las áreas bajo el marco OWASP Top 10 y OWASP API Security. Al profundizar en las diferencias entre caja negra, caja blanca y caja gris, comprendí con claridad por qué la caja gris es el estándar más eficiente y demandado en la industria: en plataformas omnicanal modernas con múltiples perfiles (como pacientes, cajeros y administradores), las vulnerabilidades más críticas no suelen ser fallas perimetrales evidentes, sino debilidades en la lógica de autorización a nivel de objeto (BOLA/IDOR) y a nivel de función (BFLA). Poder contar con credenciales parciales para validar si un usuario puede acceder a recetas médicas ajenas aporta un valor incalculable que no se logra con una caja negra.





Por otra parte, el desarrollo de las Reglas de Operación (RoE) y la ventana de usuario me permitió asimilar que el hacking ético requiere una disciplina metodológica inflexible. Establecer mecanismos de trazabilidad como el uso de cabeceras HTTP personalizadas y definir un protocolo de parada de emergencia ('Botón Rojo') son elementos indispensables para diferenciar una auditoría profesional de una intromisión negligente. Este ejercicio me brindó un panorama integral de cómo conectar los conceptos teóricos vistos en clase con las exigencias reales y normativas de una empresa que maneja datos de salud en el sureste mexicano.





8. Referencias

- Cámara de Diputados del H. Congreso de la Unión. (2021). Código Penal Federal: Título Noveno - Delitos contra la indemnidad de privacidad y la información (Artículos 211 bis 1 al 211 bis 7). Diario Oficial de la Federación. https://www.diputados.gob.mx/LeyesBiblio/pdf/CPF.pdf
- Instituto Nacional de Ciberseguridad (INCIBE). (2022). Guía de aproximación a las pruebas de penetración y seguridad ofensiva para empresas y organizaciones. INCIBE-CERT. https://www.incibe.es/guia-pentesting
- Instituto Nacional de Transparencia, Acceso a la Información y Protección de Datos Personales (INAI). (2020). Guía para el tratamiento seguro de datos personales en aplicaciones web y servicios digitales en el sector salud. INAI. https://home.inai.org.mx/
- OWASP Foundation. (2023). Guía de pruebas de seguridad para aplicaciones web (WSTG v4.2 en español) y Top 10 de riesgos en seguridad de APIs. Open Web Application Security Project. https://owasp.org/www-project-web-security-testing-guide/
- Scarfone, K., Souppaya, M., Cody, A., & Orebaugh, A. (2018). Guía técnica para pruebas y evaluaciones de seguridad de la información (Traducción y adaptación al español del estándar NIST Special Publication 800-115). National Institute of Standards and Technology / Departamento de Comercio de los Estados Unidos. https://doi.org/10.6028/NIST.SP.800-115

